Security assessment: Water Tank T-101 OT lab

Assessment date: 2026-10-05 · **Scope:** Docker build of the lab (PLC, HMI, IT/OT conduit firewall, Suricata sensor) plus Wazuh rule validation · **Method:** baseline capture → controlled anomaly tests → detection review → control gap analysis, against IEC 62443-3-3 and MITRE ATT&CK for ICS.

1. Executive summary

The IT/OT zone boundary is enforced as designed: Modbus from the IT network is logged and dropped. Network monitoring of the control zone works with **zero false positives** on the baseline and immediate detection of an unauthorised Modbus client. The main gap is that **the PLC itself accepts Modbus from any host on the OT network**: the unauthorised client was detected but still served. Modbus/TCP has no authentication, so in-zone access control has to come from host/switch allow-lists, backed by the in-PLC safety interlock and setpoint validation.

ID	Finding	Severity	Status
F-01	PLC serves Modbus requests from any OT host	**High**	Mitigation defined (host allow-list, switch port security)
F-02	IT→OT boundary blocks and logs Modbus	Pass	—
F-03	Modbus/TCP lacks authentication and integrity (protocol-inherent)	High (accepted)	Compensating controls: segmentation, IDS, in-PLC validation
F-04	OpenPLC and ScadaBR ship with default credentials	Medium	Hardening steps documented
F-05	The PLC provides both control and protection (no independent SIS)	Medium	Accepted for lab; noted for real deployments
F-06	HMI compromise inherits authorised Modbus access	Medium	Write-pattern rules (9000004/5/13) + correlation 100204

2. Environment

See `architecture/ip-addressing.md` and `architecture/network-diagram.svg`. Three zones (IT SL-1, DMZ SL-2, OT SL-2), one conduit firewall, a Suricata sensor tapping the PLC port, and Wazuh as SIEM.

3. Baseline

119 s capture on the PLC interface (`pcaps/baseline-normal-modbus.pcap`): one master (10.30.30.20), FC1 and FC3 only, 1 Hz. Replayed through the 13 OT Suricata rules: **0 alerts**.

4. Tests & results

Test	Expected	Observed	Evidence
T1 Unauthorised OT host reads PLC (FC3, read-only)	Detected; ideally blocked	**Detected** (SID 9000001). **Not blocked** (PLC returned registers) → F-01	`detection/evidence/`

Test	Expected	Observed	Evidence
T2 IT host connects to PLC :502	Blocked + logged	**Blocked**, 4/4 SYNs logged and dropped	iptables counters
T3 Wazuh rule paths (5)	Correct rule and level	**5/5 correct**, incl. level-15 recon→write correlation	`detection/evidence/README.md`
T4 Control logic incl. interlock and setpoint validation	Unit tests pass	**7/7 pass**	`tests/`

5. Recommendations (prioritised)

1. **Host-based Modbus allow-list on the PLC** (only the HMI → 502) and **switch port security / 802.1X** on the OT switch. *(F-01; SR 2.1, SR 5.1)*
2. **Change all default credentials**; separate operator and engineer roles in ScadaBR. *(F-04; SR 1.1, SR 1.5)*
3. **Engineering access only via the MFA jump host**, with PLC programming time-boxed to maintenance windows. *(SR 1.13, SR 2.1)*
4. **Keep the HMI's write footprint minimal** (only the valve coil settable) so write-target rules stay high-fidelity. *(F-06)*
5. **FIM on PLC program and HMI project**, with changes tied to change tickets. *(SR 3.4)*
6. For real deployments, an **independent SIS** for overflow protection. *(F-05)*
7. Where the hardware supports it, move to **Modbus/TCP Security (TLS, port 802)** or put PLC access behind an authenticating industrial firewall/DPI that enforces function-code allow-lists. *(F-03)*

6. Limitations

- The process-manipulation scenario (03) has its detection logic and in-PLC safeguards implemented and rule-tested, but live execution is planned for the VM build.
- Docker networking approximates VLANs and switch behaviour. Layer-2 attacks (ARP spoofing, rogue DHCP) are out of scope for this build.